

Performing Vulnerability Assessments

Objectives

- Define risk and risk management
- Describe the components of risk management

Risk Management, Assessment, and Mitigation

- One of the most important assets any organization possesses is its data
- Unfortunately, the importance of data is generally underestimated
- The first steps in data protection actually begin with understanding risks and risk management

What Is Risk?

- In information security, a risk is the likelihood that a threat agent will exploit a vulnerability
- More generally, a risk can be defined as an event or condition that could occur
 - And if it does occur, then it has a negative impact
- Risk generally denotes a potential negative impact to an asset

Definition of Risk Management

- Realistically, risk cannot ever be entirely eliminated
 - Would cost too much or take too long
- Rather, some degree of risk must always be assumed
- **Risk management**
 - A systematic and structured approach to managing the potential for loss that is related to a threat
 - Its goal is to minimize risk to an asset

Steps in Risk Management

- Asset identification.
- Threat identification.
- Vulnerability assessment.
- Risk assessment.
- Risk mitigation.

Steps in Risk Management (cont.)

Asset identification

- The first step or task in risk management is to determine the **assets** that need to be protected
- An asset is defined as any item that has a positive economic value
- Asset identification is the process of inventorying and managing these items.

Types of assets:

- Data (inventory records)
- Hardware (PCs, servers)
- Personnel (employees, customers)
- Physical assets (buildings, cars)
- Software (operating system)

Steps in Risk Management (continued)

- Along with the assets, the attributes of the assets need to be compiled
- Important to determine each item's **relative value**
- Factors that should be considered in determining the relative value are:
 - How critical is this asset to the goals of the organization?
 - How difficult would it be to replace it?
 - How much does it cost to protect it?
 - How much revenue does it generate?

Steps in Risk Management (continued)

- Factors that should be considered in determining the relative value are: (continued)
 - How quickly can it be replaced?
 - What is the cost to replace it?
 - What is the impact to the organization if this asset is unavailable?
 - What is the security implication if this asset is unavailable?

Attribute Name	Description
Equipment name	The name of the device commonly used, such as <i>Web Server 6-10</i>
Equipment type	Type of equipment, such as desktop or intrusion detection device
Manufacturer	The name of the manufacturer
Model and part number	The identification numbers used by the manufacturer
Manufacturer serial number	The unique serial number assigned by the manufacturer
Inventory tag number	The number assigned by the organization to the item; this is useful as a cross reference to the order inventory, which contains additional information such as the date purchased, the vendor's name, and the cost
Software or firmware version	The version of the software or firmware, including all updates and service packs installed
Location	The building and room number where the equipment is installed
Addresses	The Media Access Control (MAC) address and the IP address of the hardware or the hardware on which the software resides
Unit	The name of the organizational unit that is responsible for the asset
Function	A description of what the asset does

Table 9-1 Hardware and software attributes

Steps in Risk Management (continued)

- **Threat identification**

- The next step is to determine the threats from threat agents

- **Threat agent**

- Any person or thing with the power to carry out a threat against an asset

- **Threat modeling**

- Constructs scenarios of the types of threats that assets can face
- Helps to understand who the attackers are, why they attack, and what types of attacks might occur

Category of Threat	Example
Natural disasters	Fire, flood, earthquake
Compromise of intellectual property	Software piracy or copyright infringement
Espionage	Spy steals production schedule
Extortion	Mail clerk is blackmailed into intercepting letters
Hardware failure or errors	Network intrusion prevention system (NIPS) blocks all network traffic
Human error	Employee drops laptop computer in parking lot
Sabotage or vandalism	Attacker implants worm that erases files
Software attacks	Virus, worm, denial of service
Software failure or errors	Bug prevents program from properly loading
Technical obsolescence	Program does not function under new version of operating system
Theft	Desktop system is stolen from unlocked room
Utility interruption	Electrical power is cut off

Table 9-2 Common threat agents

Steps in Risk Management (continued)

- A valuable tool used in threat modeling is the construction of an attack tree.
- **Attack tree**
 - Provides a visual image of the attacks that may occur against an asset
 - It shows the goal of the attack, the type of attacks that may happen and techniques used in the attack.

Steps in Risk Management (continued)

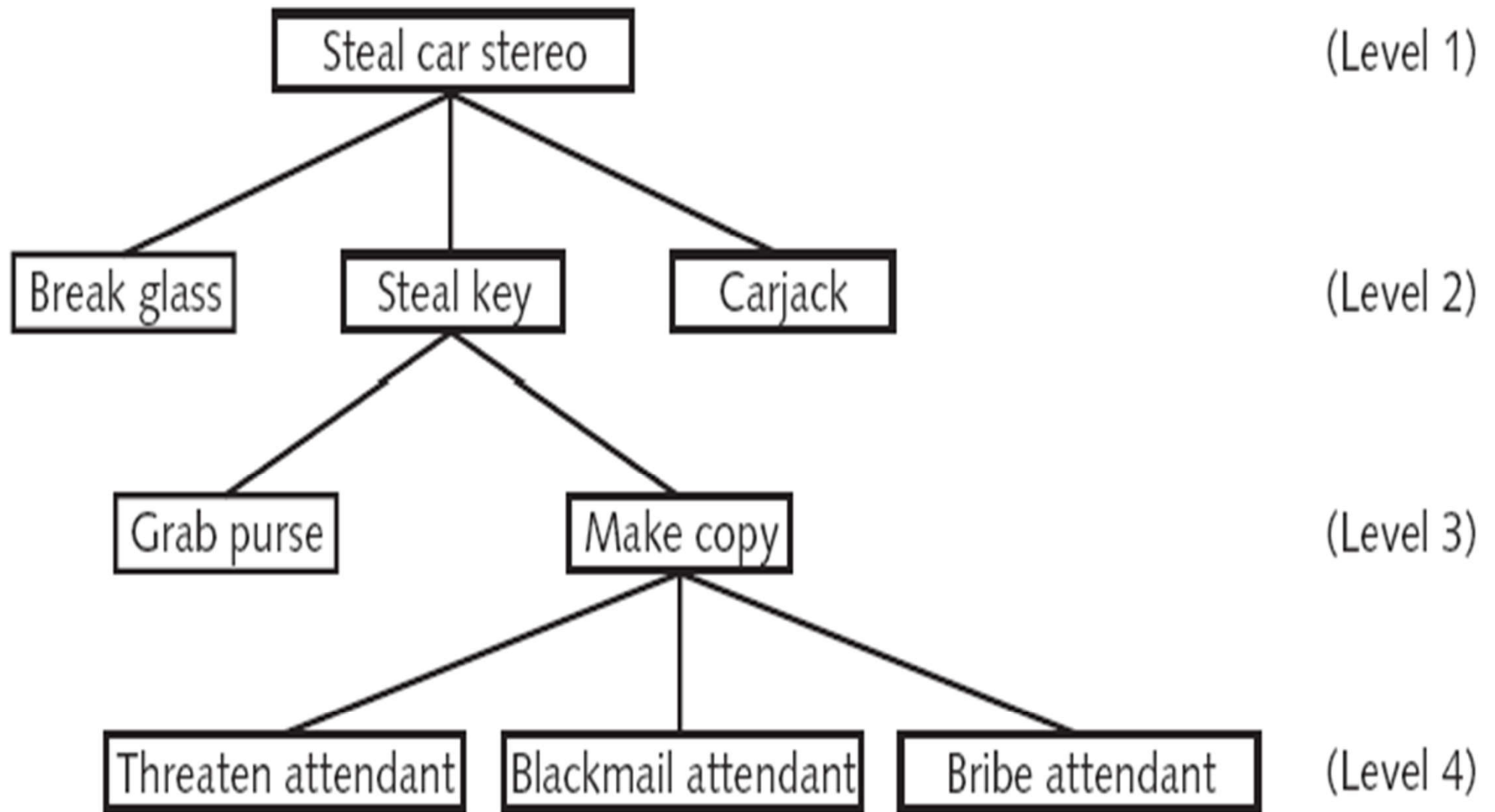


Figure 9-1 Attack tree for stealing a car stereo

Steps in Risk Management (continued)

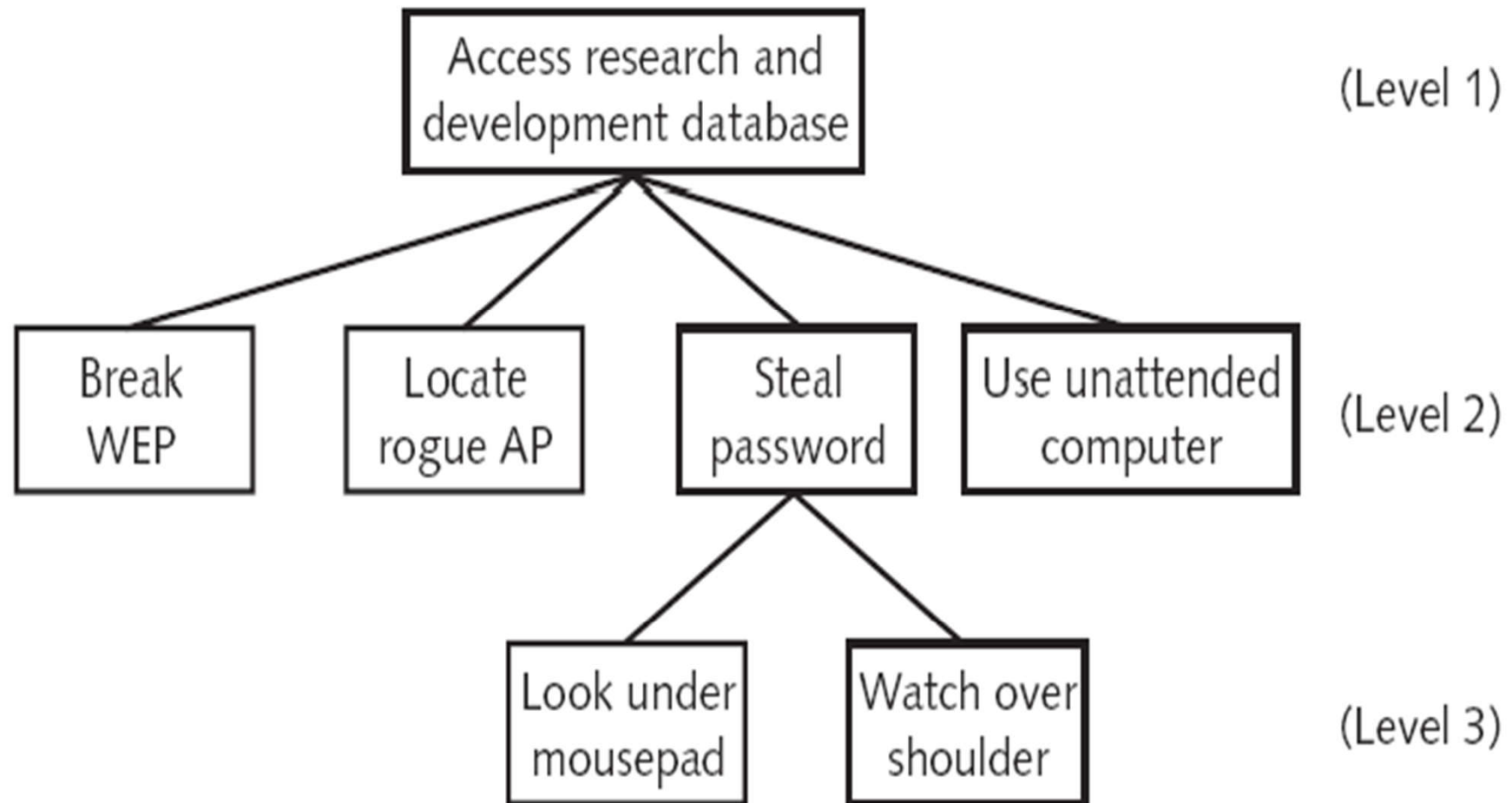


Figure 9-2 Attack tree for accessing a research and development database

Steps in Risk Management (continued)

- **Vulnerability appraisal**
 - Takes a snapshot of the security of the organization as it now stands
- Every asset must be viewed in light of each threat
- Determining vulnerabilities often depends upon the background and experience of the assessor

Steps in Risk Management (continued)

- **Risk assessment**

- Involves determining the damage that would result from an attack and the likelihood that the vulnerability is a risk to the organization
- One way to determine severity of a risk is to judge the impact that the vulnerability would have on organization if it was exploited.

Impact	Description
No impact	This vulnerability would not affect the organization. For example, the theft of a mouse attached to a desktop computer would not affect the operations of the organization.
Small impact	Small impact vulnerabilities would produce limited periods of inconvenience and possibly result in changes to a procedure. A network interface adapter card that fails might require that a spare card be made available and that all cards be periodically tested.
Significant	A vulnerability that results in a loss of employee productivity due to downtime or causes a capital outlay to alleviate it could be considered significant. Malware that is injected into the network could be classified as a significant vulnerability.
Major	Major vulnerabilities are those that have a considerably negative impact on revenue. The theft of the latest product research and development data through a back door could be considered a major vulnerability.
Catastrophic	Vulnerabilities that are ranked as catastrophic are events that would cause the organization to cease functioning or be seriously crippled in its capacity to perform. A tornado that destroys an office building and all of the company's data could be a catastrophic vulnerability.

Table 9-3 Vulnerability impact scale

Steps in Risk Management (continued)

- Calculating the anticipated losses can be helpful in determining the impact of a vulnerability
- Two formulas are commonly used to calculate expected losses
 - **Single Loss Expectancy (SLE)**
 - The expected monetary loss every time a risk occurs
 - Calculated by: **$SLE = AV * EF$**
 - **Annualized Loss Expectancy (ALE)**
 - The expected monetary loss that can be expected for an asset due to a risk over a one-year period
 - Calculated by: **$ALE = SLE * ARO$**

Steps in Risk Management (continued)

- Next step is to estimate the probability that the vulnerability will actually occur. Based on advance statistical models or a “best guess” approach and create a ranking system from 1 to10.

Steps in Risk Management (continued)

- **Risk mitigation**
 - The final step is to determine what to do about the risks
- Options when confronted with a risk:
 - Diminish the risk
 - Transfer the risk
 - Accept the risk

Steps in Risk Management (continued)

Risk Identification Action	Steps
1. Asset identification	A. Inventory the assets B. Record asset attributes C. Determine the asset's relative value
2. Threat identification	A. Classify threats by category B. Design attack tree
3. Vulnerability appraisal	A. Determine current weaknesses in assets B. Use vulnerability scanners on hardware and software
4. Risk assessment	A. Estimate impact of vulnerability on organization B. Calculate loss expectancy C. Estimate probability the vulnerability will occur
5. Risk mitigation	A. Decide what to do with the risk: diminish, transfer, or accept

Table 9-4 Risk identification steps

Summary

- In information security, a risk is the likelihood that a threat agent will exploit a vulnerability
- A risk management study generally involves five specific tasks